

May 3, 2026

# Audit Report

## GROUP 1

Kayla Hodge

Mark VanDike

Justin Vandrunen

Jarred Ward

Jordan Wicks

## Executive Summary

SnowBe Online completed a PCI DSS audit on April 27, 2026, to evaluate its ability to protect cardholder data within its retail and e-commerce operations. The audit covered its AWS-hosted systems, on-premises office environment in Los Angeles, and multiple storefront locations in the United States and Europe that process in-person transactions. Methods included reviewing documentation, analyzing system configurations, conducting interviews, and comparing current practices to PCI DSS requirements.

This audit was conducted by the following audit team members:

- Kayla Hodge
- Mark VanDike
- Justin Vandrunen
- Jarred Ward
- Jordan Wicks

This audit also included interviews of:

- End users (cashiers, customer support, sales staff)
- IT staff (system administrators, network engineers, AWS administrators)
- Mid-level employees (store managers, department supervisors)
- Executives (CIO, CFO, CEO)

SnowBe demonstrates some strengths, including recent updates to systems and security tools, as well as the use of encryption to protect payment information. However, the most critical findings include inadequate data handling practices for cardholder data, the absence of a formalized patch management process, and weaknesses in firewall configuration management. As a result, SnowBe faces elevated risks including data breaches, regulatory penalties, and reputational damage. Based on this audit, SnowBe is currently non-compliant with PCI DSS standards.

## Summary of Findings

### **Inadequate data handling practices for cardholder data**

SnowBe Online currently stores cardholder data within its internally managed web environment, including its WordPress-based e-commerce platform hosted on AWS. PCI DSS requires that organizations minimize the storage of cardholder data and ensure that any stored data is protected, and access is limited to only those with a legitimate business need. Based on the SAQ D responses, cardholder data is maintained within systems that are directly accessible through the organization's environment, and there is insufficient evidence that access is consistently restricted based on job roles. This indicates that current

data handling practices do not fully align with expected controls for protecting sensitive payment information. As a result, cardholder data remains exposed within internally managed systems and relies heavily on internal safeguards that may not be consistently enforced.

This issue is due to insufficient governance and oversight over how cardholder data is stored and accessed within the organization. Without clearly defined controls and enforcement mechanisms, data handling practices may vary across systems and users. This increases the likelihood of unauthorized access, particularly in environments that are accessible through external-facing systems. Threat actors frequently target such environments to exploit weaknesses and gain access to sensitive information. A successful compromise could result in data breaches, financial penalties, reputational damage, and loss of customer trust. The absence of consistent control enforcement further increases the overall risk of exposure.

To address this issue, SnowBe Online should reduce the storage of cardholder data where possible by implementing tokenization or outsourcing payment processing to a PCI-compliant third-party provider. If storage must continue, access to cardholder data should be strictly limited based on business needs and regularly reviewed. The organization should implement stronger controls to ensure consistent enforcement of access restrictions across all systems. Additional security measures, such as system hardening and regular security testing, should be applied to protect the environment. Continuous monitoring should be established to detect and respond to unauthorized access attempts. These actions will reduce risk exposure and support ongoing PCI DSS compliance.

### **The absence of a formalized patch management process**

SnowBe Online does not consistently apply security patches to system components within an appropriate timeframe, particularly for critical vulnerabilities. Based on the SAQ D responses, there is insufficient evidence to confirm that critical patches are installed within one month of release, as required by PCI DSS standards. This indicates a gap in the organization's vulnerability management process and represents a significant compliance issue. PCI DSS requires organizations to identify vulnerabilities and ensure timely remediation to maintain secure systems. The lack of a structured and repeatable patching process suggests that updates may be applied inconsistently across the environment.

This issue is due to the absence of a formalized and consistently enforced patch management process. Without defined timelines, procedures, and accountability, patching activities may be delayed or overlooked. This condition increases the risk of system compromise, as unpatched vulnerabilities are one of the most common attack vectors used by threat actors. Since SnowBe operates on a public-facing e-commerce platform and stores cardholder data, delayed patching could expose sensitive information to exploitation. A failure to address known vulnerabilities in a timely manner increases the likelihood of unauthorized access and potential data breaches. These weaknesses also make it difficult to demonstrate compliance with security standards and regulatory expectations.

To address this issue, SnowBe should implement a formal patch management process that includes defined timelines for applying updates, prioritization of critical vulnerabilities, and regular verification of patch status across all systems. The organization should also maintain documentation of patching activities and perform routine vulnerability scans to ensure compliance. A centralized tracking system should be used to monitor patch status and ensure accountability across all systems. Regular reviews should be conducted to confirm that patching procedures are being followed consistently. Strengthening this process will reduce risk exposure and support ongoing PCI DSS compliance. Establishing a structured approach will also improve overall system security and operational reliability.

### **Weaknesses in firewall configuration management**

SnowBe Online does not maintain fully documented or consistently enforced firewall configuration standards across its environment. PCI DSS requires that organizations establish and maintain configuration standards for firewalls and routers, restrict network traffic to only what is necessary, and maintain accurate network and data flow documentation. Based on the SAQ D assessment, there is insufficient evidence that firewall rules are formally documented, consistently applied, or regularly reviewed to ensure they remain appropriate. Additionally, network and data flow documentation is incomplete or not kept current, limiting visibility into how traffic is controlled. This indicates that firewall management practices are not fully aligned with required security controls. As a result, network boundaries may not be effectively defined or enforced.

This issue is due to the absence of formal processes and oversight for managing firewall configurations. Without clearly defined procedures for documenting, reviewing, and updating firewall rules, configurations may become inconsistent or outdated over time. This increases the risk that unnecessary or insecure network access remains enabled without detection. Weak firewall management reduces the organization's ability to control traffic entering and leaving sensitive systems. This creates opportunities for unauthorized access and increases the likelihood of a security breach. Inadequate visibility into network traffic further limits the ability to detect and respond to potential threats.

To address this issue, SnowBe Online should establish and enforce formal firewall configuration standards across all systems. The organization should implement procedures to document, review, and regularly update firewall rules to ensure only necessary traffic is permitted. Network and data flow diagrams should be maintained and kept current to improve visibility and control over the environment. Firewall configurations should be consistently applied and monitored across all systems to prevent misconfiguration. Regular reviews should be conducted to validate that controls remain effective over time. These actions will strengthen network security and support ongoing PCI DSS compliance.

**The lack of proper access control and authentication practices**

SnowBe Online has implemented some access restrictions to limit access to certain systems and data; however, access control practices are not consistently enforced across the environment. PCI DSS requires that access to systems and cardholder data be restricted based on business needs and that each user be assigned a unique account to ensure accountability. Based on the SAQ D assessment, there is insufficient evidence that access is consistently aligned with defined job roles, or that unique authentication is enforced across all systems. While some corrected items now require specific permission, this does not demonstrate that access control is applied uniformly or governed by a formal process. The presence of shared credentials and broad access in certain areas indicates that controls are not fully implemented. As a result, access to sensitive systems may not be appropriately restricted or monitored.

This issue is due to the absence of a formalized and consistently enforced access control framework. Without clearly defined roles, access requirements, and regular reviews, permissions may be assigned too broadly or inconsistently across users. Partial improvements, such as restricting access to certain systems, have been made but are not supported by structured policies or ongoing oversight. The continued use of shared credentials further weakens accountability and makes it difficult to trace user activity. These conditions increase the risk of unauthorized access and reduce the organization's ability to detect and investigate suspicious behavior. Weak access control practices can lead to data exposure, misuse of sensitive information, and potential security incidents.

To address this issue, SnowBe Online should implement a formal access control framework that defines roles and limits access based on business needs. Each user should be assigned a unique account to ensure accountability and traceability of actions. The organization should eliminate shared credentials and enforce consistent authentication practices across all systems. Access permissions should be regularly reviewed and updated to ensure they remain appropriate. Monitoring mechanisms should be implemented to track user activity and detect suspicious behavior. These actions will strengthen access control practices and support ongoing PCI DSS compliance.

**The absence of data-retention/disposal processes, policies, and/or procedures**

SnowBe currently does not have any data-retention or data disposal processes, policies, or procedures for cardholder data. This potentially puts cardholder and client data at risk of being compromised and/or stolen. This creates exposure for SnowBe to potential legal penalties, reputational damage, and system breaches. Without formal processes, policies, or procedures, SnowBe Online cannot remain compliant with certain frameworks such as PCI DSS and SOX. PCI DSS requires organizations to define and implement data retention and secure data disposal processes to ensure cardholder data is only kept as long as necessary and is properly removed when no longer needed.

This issue is due to a lack of any process for data retention, deletion, and/or disposal within SnowBe Online networks. Without a documented approach to how SnowBe retains, deletes, and disposes of

customer/client data, SnowBe may face security vulnerabilities and unnecessary storage costs. Data may also become inaccurate if there are multiple versions of a document that are not updated regularly. Breaches can occur from old and unnecessary records/data, which can cause an attack to have a greater impact on system integrity and financial stability. These conditions increase overall risk exposure and reduce the organization's ability to manage data effectively.

To address this issue, SnowBe Online should implement a Data Lifecycle Management program which will improve data retention practices. Prior to implementing Data Lifecycle Management, SnowBe should define the data in its systems and categorize it based on sensitivity. After defining the data, automated disposal can be used, and system settings can be configured for how long data is kept on file and what types of data are retained. SnowBe should also ensure a "stop button" for automated deletion in the event of a lawsuit. These recommendations will help SnowBe improve data retention, data deletion, and data disposal.